بسم الله الرحمن الرحيم

furqan-lint vs. bandit: A Finding-Count Comparison Across 25 Python Codebases

Bilal Syed Arfeen
BayyinahEnterprise

November 2026

Abstract

We compare furqan-lint v2.1.0, a static analysis tool checking for structural honesty (whether a program's surface behavior matches its substrate behavior), against bandit 1.9.4 across 25 open-source Python packages (2,327,868 lines, 5,252 files). With symmetric test-path exclusion for both tools, furqan-lint produces more findings than bandit in all 25 packages (pooled ratio 6.3x, median per-package ratio 5.3x). Without the exclusion (as run), furqan-lint leads in 22 of 25 packages (pooled 0.83x, median 5.0x), with the reversal in three scientific computing packages driven entirely by bandit's B101 (assert_used) firing on test files that furqan-lint's SI-006 exempts. Two furqan-lint rules -- SI-001 (Any annotation, 47.1%) and SI-006 (assert, 11.5%) -- account for 58.6% of output; SI-001 duplicates ruff's ANN401. Whether these counts represent a complementary analysis class requires an overlap decomposition and precision measurement we have not performed. We provide raw JSON from both tools for all 25 packages.

Note on terminology. Finding means a pattern flagged by a tool's rule. The false positive rate is not measured. We present count differences, not defect counts.

---

1. Introduction

Static analysis tools for Python fall into established categories: style checkers (ruff, flake8), type checkers (mypy, pyright), and security scanners (bandit, semgrep). We examine whether a tool organized around *structural honesty* -- gaps between what code's interface claims and what its implementation does -- produces meaningfully different findings.

furqan-lint v2.1.0 implements 42 Python rules in four families:

- **RING-CLOSE (RC)**: unclosed resources (5 rules)
- **MARAD (MR)**: silent failure (5 rules: MR-001/002/003/005/007)
- **TRUST-BOUNDARY (TB)**: security boundaries (22 active + 3 informational, off by default)
- **SCAN-INCOMPLETE (SI)**: abandoned analysis (7 rules)

Three TB rules (001/002/003) flag language features rather than likely problems and are off by default. All results use the default: 39 active rules. Eight additional rules exist only in non-Python adapters (C, C++, Java, C#, Ada/SPARK), for 50 unique rule IDs across six languages. Only the 39 active Python rules are evaluated here.

Some of furqan-lint's rules overlap with rules in existing tools. SI-001 (Any annotation) duplicates ruff's ANN401. Several TB rules (hardcoded secrets, insecure hash, eval/exec) overlap with bandit rules. Of the three motivating patterns below, two have existing coverage: broad except-catching (ruff BLE001, pylint W0718) and hardcoded passwords (bandit B105). The third -- kwargs passthrough without validation -- appears unique to furqan-lint.

Examples of structural honesty findings:

- An `except Exception` block that catches everything but re-raises nothing.
- A parameter named `password` assigned the literal string `"admin123"`.
- `**kwargs` accepted and passed through without validation.

---

2. Method

2.1 Package selection

25 packages from PyPI, selected for domain diversity (web frameworks, HTTP clients, data science, ORMs, task queues, templating, cryptography, SSH, scraping, CLIs, cloud SDKs, image processing). Size: 6,385 lines (requests) to 635,499 (pandas). The selection is convenience-based: widely-used production packages chosen before scanning.

2.2 Tools

Tool	Version	Configuration
furqan-lint	v2.1.0	Default (39 active Python rules)
bandit	1.9.4	Default (all rules)

2.3 Procedure

Each package scanned in installed form (site-packages). Both tools run with default configuration.

Test-path asymmetry. furqan-lint's SI-006 (assert usage) exempts test files (test_ prefix, _test.py suffix, conftest.py, or tests/test directory component). bandit's B101 (assert_used) does not. Installed packages include test files (~36% of total lines). This asymmetry drives the 0.2x--0.3x ratios in numpy, pandas, and scipy.

Non-Python findings. furqan-lint's tree-sitter adapters scanned 76 non-Python files (.c/.h/.cpp) bundled in numpy's site-packages, producing 76 findings. These are reported separately.

2.4 Threats to validity

1. **Overlap.** We do not decompose findings into overlapping and unique categories. 2. **Precision.** Neither tool's false positive rate is measured. SI-001 (47.1% of output) may have a high false-positive rate. 3. **Test-path asymmetry.** Documented above; a sensitivity analysis follows. 4. **Rule concentration.** Two rules produce 58.6% of output. 5. **SI-001 duplicates ruff ANN401.** 6. **Single bandit version (1.9.4).** 7. **Convenience sample.** Package selection cannot be verified as unbiased.

---

3. Results

3.1 Sensitivity: as run vs. symmetric test-path exclusion

Condition	furqan total	bandit total	Pooled ratio	furqan > bandit	Median per-pkg
As run	24,933	29,959	0.83x	22 / 25	5.0x

Condition	furqan total	bandit total	Pooled ratio	furqan > bandit	Median per-pkg
Both exclude test paths	22,888	3,615	6.33x	25 / 25	5.3x

The as-run pooled ratio (0.83x) is an artifact of the SI-006/B101 asymmetry. Under symmetric test-path exclusion, furqan-lint produces more findings in all 25 packages.

3.2 Per-package results (as run)

Package	Domain	Files	Lines	furqan	bandit	Ratio
django	Web framework	909	165,634	1,605	281	5.7x
flask	Micro web	24	9,199	76	13	5.8x
fastapi	Async web	52	22,748	688	70	9.8x
tornado	Async networking	76	50,586	947	285	3.3x
starlette	ASGI	36	6,947	313	73	4.3x
requests	HTTP library	19	6,385	149	16	9.3x
httpx	Async HTTP	23	8,828	84	29	2.9x
urllib3	HTTP low-level	36	11,914	99	10	9.9x
aiohttp	Async HTTP	54	28,467	662	178	3.7x
sqlalchemy	SQL ORM	258	253,997	8,496	866	9.8x
celery	Task queue	161	47,496	703	49	14.3x
jinja2	Template engine	25	14,425	239	62	3.9x
pydantic	Data validation	105	45,762	2,099	86	24.4x
cryptography	Crypto library	78	13,868	52	18	2.9x
paramiko	SSH library	42	18,621	204	21	9.7x
scrapy	Web scraping	199	38,503	1,361	241	5.6x
click	CLI framework	17	12,674	94	36	2.6x
rich	Rich terminal	100	38,515	200	58	3.4x
typer	CLI builder	32	13,911	486	60	8.1x
boto3	AWS SDK	39	8,558	38	0	--
PIL	Image processing	98	35,149	652	288	2.3x
werkzeug	WSGI utilities	52	21,687	184	28	6.6x
numpy	Numerical	407	243,710	1,018	3,597	0.3x
pandas	Data analysis	1,422	635,499	2,657	17,701	0.2x
scipy	Scientific	988	574,785	1,827	5,893	0.3x

3.3 Ratio distribution (as run, n=24 excluding boto3)

Metric	Value
Mean	6.2x
Median	5.0x
SD	5.3
Min	0.2x (pandas)
Max	24.4x (pydantic)

3.4 Finding density

Metric	furqan	bandit
Pooled (per KLOC)	10.7	12.9
Range (per KLOC)	3.2 -- 45.9	0.0 -- 27.8

3.5 Severity distribution (Python findings only: 24,857)

Severity	Count	Percentage
CRITICAL	297	1.2%
HIGH	1,918	7.7%
MEDIUM	17,800	71.6%
LOW	4,842	19.5%

76 non-Python findings (from numpy's bundled C code) are excluded from this table: TB-029 (34), TB-030 (19), SI-004 (12), TB-033 (4), TB-032 (4), TB-026 (2), TB-018 (1). CRITICAL Python findings: TB-006 pickle/yaml (153), TB-005 eval/exec (115), MR-001 bare except (29).

3.6 Per-rule concentration

Rule	Count	%	Description
SI-001	11,742	47.1%	Any type annotation (cf. ruff ANN401)
SI-006	2,872	11.5%	assert in non-test code (cf. bandit B101)
SI-005	2,794	11.2%	**kwargs passthrough
SI-007	2,017	8.1%	hasattr() swallows AttributeError
SI-004	1,894	7.6%	TODO/FIXME comment
MR-005	964	3.9%	Empty except block
Other (35 rules)	2,650	10.6%	

Two rules produce 58.6%. Top 6 produce 89.4%. 35 rules share the remaining 10.6%.

---

4. Discussion

4.1 What the counts show

furqan-lint produces different finding counts from different rules than bandit. Under symmetric test-path treatment (both excluding), it produces more findings in all 25 packages. The bulk of those findings come from rules with no bandit equivalent (SI-001, SI-005, SI-007, SI-004, MR-005), though SI-001 duplicates ruff's ANN401 and SI-006 overlaps with bandit's B101.

4.2 What the counts do not show

Whether the additional findings are true positives or noise. Whether the non-overlapping rules detect genuine problems that matter in practice. Whether "structural honesty" is a coherent analysis class or a collection of unrelated heuristics. Answering these requires a precision study on a labeled sample, which is beyond this paper's scope.

4.3 Limitations

1. Finding count is not defect count. SI-001 (47.1%) may have a high false-positive rate. 2. No overlap decomposition performed. 3. Two rules produce 58.6% of output. 4. SI-001 duplicates ruff ANN401. 5. Test-path

asymmetry between SI-006 and B101 (sensitivity table provided). 6. 76 non-Python findings from numpy's C code (reported separately). 7. Convenience sample. 8. Single bandit version.

---

5. Conclusion

furqan-lint v2.1.0 produces more findings than bandit in 25 of 25 packages under symmetric test-path exclusion (median 5.3x, pooled 6.3x), and 22 of 25 as run (median 5.0x, pooled 0.83x). Two rules account for 58.6% of output, one of which duplicates existing coverage (ruff ANN401).

Whether this constitutes a complementary analysis class is an open question requiring overlap decomposition and precision measurement. The data to answer it -- raw JSON from both tools on all 25 packages -- is shipped with this paper.

The tool is open-source under Apache-2.0: **https://github.com/BayyinahEnterprise/Kun-Fayakun**

Data availability

benchmark_v2.1.0.csv, raw_json/ (furqan-lint), bandit_json/ (bandit), benchmark.py, test_output_v2.1.0.txt (183 tests passing). Tools: furqan-lint v2.1.0, bandit 1.9.4, Python 3.13.18.

References

[1] B. S. Arfeen, "Structural Honesty Verification: On Surface-Substrate Divergence Across Systems," BayyinahEnterprise, 2026.

[2] PyCQA, "Bandit: Security linter for Python," https://bandit.readthedocs.io/

[3] M. Brunsfeld et al., "Tree-sitter: An incremental parsing system for programming tools," https://tree-sitter.github.io/tree-sitter/

[4] OASIS, "Static Analysis Results Interchange Format (SARIF) Version 2.1.0," 2020.

بسم الله الرحمن الرحيم